

Mapeo detallado de preguntas a requisitos normativos (versión KEV)

Esta tabla vincula cada pregunta del modelo de encuesta con los principales marcos de referencia y normativas relevantes, haciendo especial énfasis en la gestión de vulnerabilidades explotadas conocidas (KEV).

Abreviaturas empleadas:

- ISO 27001 – Sistema de gestión de la seguridad de la información.
- ISO 27002 – Controles de seguridad.
- ISO 27005 – Gestión de riesgos.
- NIST CSF – NIST Cybersecurity Framework.
- ENS – Esquema Nacional de Seguridad (España).
- NIS2 – Directiva (UE) 2022/2555 sobre medidas para un elevado nivel común de ciberseguridad.
- CISA BOD 22-01 – Directiva de CISA sobre KEV para agencias federales.

Nota: el mapeo es deliberadamente de alto nivel para mantenerlo manejable; puede ampliarse con referencias a controles/subcontroles específicos si se requiere mayor granularidad.

ID Pregunta	Bloque	Tema principal	Referencias normativas/marcos	Comentario de alineamiento
PERF-01	PERF	Tipo de organización	ISO 27001 (Contexto), NIS2 (Art. 3–4)	Ayuda a determinar la aplicabilidad de requisitos (entidad esencial/importante, organismo público, etc.).
PERF-02	PERF	Tamaño de la organización	ISO 27001 (Contexto), ENS (Ámbito)	Permite ajustar el nivel de exigencia y la proporcionalidad de controles.
PERF-03	PERF	Sector de actividad	NIS2 (Anexo I–II), ENS	Relaciona la organización con los sectores críticos definidos por NIS2 y ENS.
PERF-04	PERF	Ámbito geográfico	NIS2, RGPD, legislación nacional	Indica complejidad regulatoria y alcance territorial de las obligaciones.
GOV-01	GOV	Política de gestión de vulnerabilidades y KEV	ISO 27001 A.5, A.8; ISO 27002 8.8; NIST CSF ID.RA, PR.IP; ENS MP.INFO; CISA BOD 22-01	Exige una política formal de gestión de vulnerabilidades, incorporando KEV como fuente prioritaria de riesgo.
GOV-02	GOV	Roles y responsabilidades sobre KEV	ISO 27001 A.5.2; NIST CSF GV; ENS ORG.1; NIS2 (gobernanza)	Refuerza la asignación clara de responsabilidades y gobierno sobre la gestión de vulnerabilidades.

GOV-03	GOV	Integración de KEV en la gestión de riesgos	ISO 27005; ISO 27001 A.5, A.8; NIST CSF ID.RA; ENS Riesgos	Alinea la consideración de KEV con los procesos formales de análisis y tratamiento de riesgos.
GOV-04	GOV	Frecuencia de revisión del catálogo KEV	NIST CSF DE.CM; ENS OP.2; CISA BOD 22-01	Promueve la monitorización continua de nuevas KEV y su impacto potencial.
GOV-05	GOV	Criterios de priorización de vulnerabilidades	ISO 27002 8.8; NIST CSF PR.IP; NIST SP 800-40; ENS MP.SI	Introduce priorización basada en riesgo real (CVSS/EPSS/KEV) en lugar de listas de parches indiscriminadas.
GOV-06	GOV	SLAs de remediación para KEV	CISA BOD 22-01; NIST CSF RS.MI; ENS MP.SI; NIS2 Art. 21	Conecta plazos de remediación con requerimientos regulatorios y de gestión de incidentes.
VUL-01	VUL	Inventario de activos	ISO 27001 A.5, A.8; NIST CSF ID.AM; ENS MP.SI	El inventario es la base para saber qué está potencialmente afectado por KEV.
VUL-02	VUL	Escaneo y detección de vulnerabilidades (etiqueta KEV)	ISO 27002 8.8; NIST CSF PR.IP, DE.CM; CISA KEV	Garantiza el uso de herramientas que identifiquen específicamente vulnerabilidades explotadas.
VUL-03	VUL	Correlación KEV-activos	NIST CSF ID.AM, PR.IP; ENS MP.SI	Mide la capacidad de vincular vulnerabilidades explotadas con activos concretos de la organización.

VUL-04	VUL	Medición del tiempo de remediación de KEV	NIST CSF RS.MI, PR.IP; ENS indicadores	Alinea el seguimiento de tiempos de parcheo con la mejora continua de procesos.
VUL-05	VUL	Cumplimiento de plazos de remediación	CISA BOD 22-01; NIS2 Art. 21; NIST CSF RS.MI	Facilita la supervisión del cumplimiento de plazos similares a los exigidos a agencias federales y operadores esenciales.
VUL-06	VUL	Tratamiento de dispositivos perimetrales	ISO 27001 A.8, A.10; NIST CSF PR.AC, PR.PT; ENS MP.COM	Pone el foco en los sistemas más atacados (perímetro, VPN, firewalls).
VUL-07	VUL	Gestión de sistemas legacy	ISO 27002 (ciclo de vida); NIST CSF ID.AM, PR.IP; ENS MP.SI	Aborda el riesgo de tecnologías obsoletas donde las KEV suelen permanecer abiertas.
PEN-01	PEN	Frecuencia de pentests	ISO 27001 A.8.8; NIST CSF PR.IP, DE.CM; ENS OP.2	Relaciona las pruebas periódicas con buenas prácticas de verificación de seguridad.
PEN-02	PEN	Cobertura de KEV en pentests	NIST CSF PR.IP, DE.CM; CISA KEV	Garantiza que los escenarios de prueba se alinean con vulnerabilidades explotadas reales.
PEN-03	PEN	Gestión de hallazgos de pentest	ISO 27001 A.8.8, A.10; NIST CSF RS.MI; ENS MEJ	Integra resultados de pruebas en ciclos de corrección y mejora.

PEN-04	PEN	Ejercicios Red/Purple Team	NIST CSF DE.CM, RS.IM; ENS OP.2	Simula ataques avanzados (a menudo explotando KEV) para probar capacidades de detección y respuesta.
PEN-05	PEN	Verificación del cierre de KEV	ISO 27002 8.8; NIST CSF RS.MI	Asegura que las remediaciones aplicadas son efectivas en la práctica.
SIEM-01	SIEM	Existencia y madurez de SIEM/SOC	NIST CSF DE.CM, RS.AN; ENS OP.2	Evalúa capacidad de monitorización y análisis de eventos de seguridad.
SIEM-02	SIEM	Casos de uso para explotación de vulnerabilidades	NIST CSF DE.CM, PR.PT; CISA KEV	Refuerza el diseño de reglas de detección específicas para explotación de vulnerabilidades clave.
SIEM-03	SIEM	Fuentes de logs y cobertura	ISO 27001 A.8, A.12; NIST CSF DE.CM; ENS MP.SI	Cobertura de registro necesaria para detectar explotación de KEV.
SIEM-04	SIEM	Integración de inteligencia de amenazas	NIST CSF ID.RA, DE.CM; NIS2 Art. 21	Promueve consumo sistemático de feeds (incluido KEV) en el SOC.
SIEM-05	SIEM	Detección basada en comportamiento	NIST CSF DE.CM; ISO 27002 monitorización	Focaliza en capacidades avanzadas (EDR/NDR/UEBA) para detectar explotación sofisticada.
SIEM-06	SIEM	Medición de MTTD	NIST CSF DE.CM, RS.MI; ENS indicadores	Mide la rapidez de detección de incidentes, clave para limitar impacto.

AWR-01	AWR	Programa de formación general	ISO 27001 A.6; ISO 27002 concienciación; NIST CSF PR.AT; ENS ORG.4	Asegura capacitación mínima para todo el personal.
AWR-02	AWR	Formación técnica en vulnerabilidades/ KEV	ISO 27001 A.7; NIST CSF PR.AT; NIS2 Art. 20	Refuerza competencias de administradores, desarrolladores y personal de seguridad.
AWR-03	AWR	Simulaciones y ejercicios de concienciación	NIST CSF PR.AT; ENS concienciación	Incentiva campañas prácticas (phishing, respuesta básica, etc.).
AWR-04	AWR	Cultura de reporte de incidentes	ISO 27035; NIST CSF RS.CO; ENS OP.4	Evalúa la predisposición del personal a informar de situaciones sospechosas.
AWR-05	AWR	Medición de eficacia de la capacitación	ISO 27004; NIST CSF ME; ENS MEJ	Conecta la formación con métricas de resultado, no solo de actividad.
MET-01	MET	Indicadores de vulnerabilidades y KEV	ISO 27004; NIST CSF ME; ENS indicadores	Asegura la existencia de métricas significativas ligadas a KEV.
MET-02	MET	Indicadores de pentesting y SIEM	ISO 27004; NIST CSF ME; ENS MEJ	Facilita la evaluación del rendimiento de controles técnicos.
MET-03	MET	Uso de benchmarks externos	NIST CSF ID.RA, ME; informes ENISA/CISA	Promueve la comparación con el entorno y la mejora basada en evidencia.
MET-04	MET	Cálculo de ROI en seguridad	ISO 27005; NIST CSF GV; NIS2 (gobernanza)	Conecta iniciativas de seguridad con análisis coste/beneficio.

MET-05	MET	Madurez percibida en KEV/vulnerabilidades	ISO 27004; NIST CSF ME	Recoge autopercepción como complemento cualitativo a indicadores cuantitativos.
IMP-01	IMP	Existencia de plan de mejora	ISO 27001 A.10; NIST CSF IM; ENS MEJ	Evalúa si hay un programa estructurado de mejora continua.
IMP-02	IMP	Obstáculos percibidos	NIST CSF GV, RS; gestión del cambio	Identifica barreras para la implantación efectiva de controles normativos.
IMP-03	IMP	Comentarios abiertos	–	Proporciona contexto adicional para interpretar el grado de cumplimiento y adecuación de marcos.

Este mapeo permite a auditores, reguladores y responsables de ciberseguridad enlazar cada resultado de la encuesta con requisitos concretos de los marcos de referencia, facilitando:

- Justificación de inversiones y prioridades.
- Preparación de auditorías formales.
- Alineamiento con la transposición de NIS2 y la aplicación del ENS.